# SIMATS ENGINEERING ASSESSMENT
## TOOL 2

**COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY**
**COURSE CODE: CSA51**

---

**COURSE OUTCOME COVERED**

**CO2:** Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

**Scenario-Based : 20%**

**QUESTIONS:** **Total Marks: 50**

**Annexure A**

---

***Code of Conduct:***

*I **DHARANIDARAN D ( 192521337 )** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

***Dharanidaran D***
***Signature of the student:***

**Annexure A**
**Scenario-based**

1. **Secure Data Transmission using Block Cipher**
   **A company is transmitting repeated financial data blocks over a network. Initially, they used ECB mode and noticed patterns in ciphertext.**
   **A. Explain why this issue occurs.**
   **B. Suggest a more secure block cipher mode and justify your choice based on the scenario.**

# Comprehensive Cryptographic Analysis of Block Cipher Operational Modes

## Electronic Codebook Vulnerability Assessment and Alternative Architecture Selection

### Underlying Cause of Leaked Patterns in ECB Configurations:

The core issue stems from the fact that Electronic Codebook (ECB) mode functions as a direct lookup table where each plaintext block is mapped independently to a ciphertext block using the exact same secret cryptographic key. Because financial data streams are inherently highly structured—often containing predictable headers, recurring transaction values, padding strings, or repeating zero fields—identical input blocks will invariably produce identical output blocks. This deterministic nature means that ECB mode does not provide semantic security; it completely preserves the structural patterns, alignment, and

distribution of the underlying plaintext within the ciphertext layer itself. Consequently, any passive network eavesdropper monitoring the corporate transmission line can easily conduct statistical analysis to determine when identical financial transactions are repeated, infer the boundaries of message fields, and deduce sensitive financial activity without ever having to break or decrypt the master key.

## Architectural Recommendation and Operational Justification for Cipher Block Chaining (CBC):

To completely eliminate the deterministic vulnerabilities of ECB mode, the company must immediately transition to Cipher Block Chaining (CBC) mode or Counter (CTR) mode, with CBC being an exemplary standard choice for structural integrity. CBC mode systematically introduces randomized diffusion by utilizing a unique, unpredictable Initialization Vector (IV) for the first block of plaintext and then chaining subsequent blocks together. Before a plaintext block undergoes the actual block cipher encryption process, it is first combined via a bitwise exclusive-OR (XOR) operation with the ciphertext block produced immediately prior to it. This structural dependency guarantees that every single ciphertext block becomes mathematically dependent on all preceding plaintext blocks, meaning that a repeating financial block located at the start of a transmission will yield a completely different ciphertext representation than an identical financial block positioned later in the stream. By breaking the direct one-to-one relationship between plaintext and ciphertext, CBC mode successfully ensures that identical financial data streams produce a

pseudorandom, high-entropy output that contains absolutely zero discernible patterns or structural leakage for external adversaries to exploit.

---

2. **Choosing an Encryption Algorithm for Banking System**
   **A banking application needs high security and moderate performance for encrypting customer transactions. The available options are DES, 3-DES, and Blowfish.**
   **A. Identify the most suitable algorithm for this scenario.**
   **B. Justify your choice based on security strength and efficiency.**

## Strategic Cryptographic Selection for Banking Transaction Systems

### Evaluation Matrix and Architectural Fit for Sensitive Financial Applications

### Identification of the Most Suitable Symmetric Cryptographic Algorithm:

Among the three specified options, Blowfish is definitively the most appropriate algorithm to deploy within this banking application framework. It perfectly aligns with the core system requirements by providing a highly robust defensive layer against contemporary cryptographic attacks while maintaining highly optimized processing throughput that ensures customer transaction processing latencies remain within acceptable, low-overhead bounds.

## Comparative Justification Based on Security Thresholds and Computational Efficiency:

The selection process requires evaluating the cryptographic limitations of the alternative options against Blowfish's structural advantages. Data Encryption Standard (DES) must be entirely disqualified because its restrictive 56-bit key length is trivially vulnerable to modern brute-force calculations and distributed cloud-based cracking setups, failing to meet the foundational high-security mandate required for financial assets. While Triple Data Encryption Standard (3-DES) remedies this security deficit by processing each data block three times using either two or three distinct keys to effectively extend the key length up to 168 bits, this iterative approach severely degrades its computational performance. The repetitive looping structure makes 3-DES highly inefficient and slow, introducing significant processing bottlenecks that would cripple a banking platform managing concurrent transaction volumes. In stark contrast, Blowfish operates on a flexible, variable key length architecture scaling up to 448 bits, providing a massively complex key space that remains resilient against brute-force attacks. Furthermore, Blowfish relies on a fast Feistel network structure optimized specifically for 32-bit hardware processors and utilizes dynamic, data-dependent S-boxes that execute rapidly in memory cache, enabling it to deliver exceptional cryptographic strength alongside vastly superior operational efficiency compared to 3-DES.

3. **Key Exchange in an Unsecured Network**

   **Two users want to establish a secure communication channel over a public network using Diffie-Hellman key exchange. However, the network is vulnerable to attacks.**

   **A. Explain how the key exchange works in this scenario.**

   **B. Identify a possible security threat and suggest a solution to mitigate it.**

## Secure Key Agreement Frameworks Over Adversarial Mediums

## Mathematical Architecture of Diffie-Hellman and Cryptographic Remediation

### Step-by-Step Mathematical Mechanics of the Key Exchange Protocol:

The Diffie-Hellman protocol allows two remote users to establish a shared symmetric cryptographic secret key over a fully monitored public network without transmitting the secret itself. The process initiates when both parties openly agree upon two public parameters: a massive prime number (\(p\)) and a

primitive root generator ($g$). User 1 selects a private, randomly generated integer ($a$) and calculates their corresponding public value ($A = g^a \bmod p$). Simultaneously, User 2 selects their own private random integer ($b$) and calculates their public value ($B = g^b \bmod p$). Both parties then broadcast their public values across the unsecure network. Upon receiving the external public value, User 1 computes the final secret key as ($K = B^a \bmod p$), while User 2 computes it as ($K = A^b \bmod p$). Due to the commutative properties of modular exponentiation, both mathematical calculations resolve to the exact same numerical result ($K = g^{ab} \bmod p$), creating a unified shared symmetric key that can safely encrypt subsequent traffic.

## Identification of Vulnerabilities and Advanced Defensive Countermeasures:

The critical security threat inherent to this native implementation is the Man-in-the-Middle (MitM) attack, which is possible because the foundational Diffie-Hellman protocol lacks any inherent identity verification or authentication mechanisms. An active adversary positioned on the network can intercept User 1’s public key ($A$) and substitute it with their own rogue public value, while doing the exact same to User 2's public key ($B$). This allows the attacker to establish two completely independent shared secrets—one with User 1 and one with User 2—enabling them to seamlessly decrypt, read, modify, and re-encrypt financial data blocks in real time without either legitimate user realizing their communication line has been fully compromised. To effectively mitigate this severe vulnerability, the organization must implement an Authenticated Diffie-Hellman variant, such as the Station-to-Station (STS)

protocol. This defense mechanism requires both endpoints to sign their exchanged public values using trusted digital signatures or validate them via X.509 digital certificates managed by an internal Public Key Infrastructure (PKI), ensuring that both parties conclusively verify the true identity of the endpoint before any cryptographic keys are generated.

---

4. **Public Key Cryptography for Email Security**
   **An organization plans to implement RSA for secure email communication.**
   **A. Describe how RSA can be used for encryption and decryption in this scenario.**
   **B. Explain how key distribution and management play a role in maintaining security.**

## Asymmetric Infrastructure Deployment for Enterprise Email Communication

## Mathematical Workflows of RSA Ciphers and Lifecycle Management Policies

### Functional Mechanisms of Asymmetric Encryption and Decryption Workflows:

The implementation of the RSA algorithm within an email environment relies upon asymmetric key pair dynamics to achieve robust data confidentiality. Each organizational user generates an mathematically linked key pair consisting of a Public Key, which is openly accessible via a corporate directory, and a Private Key, which must be stored securely and never shared. When a sender composes an email intended for a specific recipient, the email client transforms the plaintext message into a numeric format and applies the recipient's public key components ($e, n$) using the modular exponentiation formula ($C = M^e \bmod n$) to generate a garbled ciphertext. Once this encrypted email traverses the internet and reaches the destination inbox, the recipient's email client leverages their private key components ($d, n$) to compute the inverse function ($M = C^d \bmod n$). Because calculating the private key from the publicly known components requires solving the incredibly complex mathematical problem of factoring the product of two massive prime numbers, external eavesdroppers cannot decode the message, ensuring private delivery.

## Strategic Governance of Public Key Distribution and Lifecycle Protection:

Key distribution and management act as the primary operational pillars required to keep the RSA infrastructure secure against sophisticated tampering attacks. Without structured distribution controls, an adversary could execute identity-spoofing attacks by uploading a fraudulent public key to the network and falsely associating it with an executive's identity, thereby intercepting sensitive incoming communications. To prevent this, the organization must deploy a formal Public Key Infrastructure (PKI) anchored by a trusted Certificate Authority (CA) that digitally signs and certifies that each public key belongs to a verified employee. Additionally, strict key management policies must govern the

lifecycle of the private keys; they should be securely encapsulated within hardware security modules (HSMs) or encrypted local enclaves, undergo mandatory periodic rotations to limit the impact of potential key leakage, and be backed by an active Certificate Revocation List (CRL) or Online Certificate Status Protocol (OCSP) system to instantaneously invalidate certificates if an employee leaves the company or misplaces an enrolled device.

---

5. **Cryptography for IoT Devices**

   **A smart home system uses low-power IoT devices that need secure communication. The designer must choose between RSA and Elliptic Curve Cryptography (ECC).**

   **A. Analyze the constraints of IoT devices.**

   **B. Recommend a suitable cryptographic approach and justify your answer.**

## Cryptographic Architecture Optimization for Resource-Constrained Environments

### Hardware Parameter Evaluation and Elliptic Curve Paradigm Selection

### Detailed Engineering Analysis of Embedded Smart Home Hardware Constraints:

Smart home Internet of Things (IoT) devices, such as connected smart locks, ambient environmental sensors, and micro-controllers, are engineered using highly restrictive hardware footprints to minimize production costs and maintain low operational footprints. These embedded microchips operate with severely constrained central processing units (CPUs) running at low clock speeds, extremely limited random-access memory (RAM) allocations often measured in mere kilobytes, and minimal non-volatile storage capacities. Furthermore, the vast majority of these edge nodes operate on battery power or rely on harvested energy, requiring them to stay in low-power sleep modes as much as possible. Running traditional, complex mathematical operations consumes significant processing cycles, which strains the system memory, causes operational latency in real-time commands, and quickly drains the onboard battery reserves, rendering heavy cryptographic computations entirely impractical.

## Definitive Cryptographic Recommendation and Architectural Justification for ECC:

For this resource-constrained smart home architecture, Elliptic Curve Cryptography (ECC) is the highly superior choice over RSA. The foundational advantage of ECC lies in its mathematical structure, which relies on the algebraic complexity of the elliptic curve discrete logarithm problem rather than the prime factorization models utilized by RSA. This allows ECC to deliver identical cryptographic defensive strength as RSA while utilizing significantly shorter key lengths; for example, a compact 256-bit ECC key achieves the exact same security threshold as an unwieldy 3072-bit RSA key. For an embedded IoT device, this reduction in key size drastically lowers the storage space required to

hold cryptographic parameters in non-volatile flash memory and substantially reduces the RAM overhead during active runtime handshakes. Furthermore, because the underlying mathematical computations of ECC involve smaller numeric structures, the CPU requires far fewer clock cycles to complete encryption and decryption tasks, resulting in rapid execution speeds, lower network bandwidth consumption during key exchange transmissions, and an extended battery life for the smart home hardware nodes.

**RUBRICS FOR CALCULATION:**

| Criteria | Weightage (%) | Level 4 (Exemplary) | Level 3 (Proficient) | Level 2 (Developing) | Level 1 (Beginning) |
|---|---|---|---|---|---|
| Understanding of Scenario | 20% | Demonstrates clear and complete understanding of the scenario and context | Shows good understanding with minor gaps | Partial understanding; misses key aspects | Misinterprets or fails to understand the scenario |
| Identification of Key Issues | 20% | Accurately identifies all relevant issues and factors involved | Identifies most key issues with minor omissions | Identifies limited issues; some irrelevant points | Unable to identify key issues |
| Application of Concepts | 25% | Applies appropriate concepts effectively to address the scenario | Applies concepts with minor errors | Limited or partially correct application | Unable to apply relevant concepts |
| Decision Making | 20% | Makes wellreasoned, logical decisions with strong rationale | Makes reasonable decisions with some justification | Makes weak decisions with limited justification | No clear decisions made or rationale provided |
| Clarity of | 15% | Response is | Generally | Somewhat | Disorganiz |

| | | | | | |
|---|---|---|---|---|---|
| Response | | clear, structured, and logically presented | clear with minor issues | unclear or poorly structured | ed and difficult to understand |